VWO Login Dashboard

Risk-Based Test Plan

Version 1.0 | Date: 22 October 2026 | Owner: TBD | Status: Draft for review

Source: Product Requirements Document: VWO Login Dashboard (provided PDF). This plan defines proposed coverage; it does not report test execution or results.

1. Test Plan Overview

Objective: validate that the login entry point securely and accessibly authenticates VWO users, recovers common failures, and transitions authorized users into the platform. Coverage prioritizes authentication, recovery, session protection, integrations, and the PRD performance and accessibility targets.

2. Product / Change Summary

The PRD describes app.vwo.com as the entry point to VWO experimentation, personalization, and analytics. Login capabilities include email/password, remember-me, sign-up navigation, password recovery, optional MFA and enterprise SSO, responsive/accessibility support, themes, and transition to the core dashboard. The PRD sets a sub-2-second page-load target, 99.9% availability goal, and 95%+ login-success KPI.

3. Scope

In scope

- Login form, credential validation, success/failure messaging, and processing states.
- Remember-me and configurable session timeout; password reset and token lifecycle.
- Optional MFA, enterprise SSO (SAML/OAuth and other supported protocols), and optional social login when enabled.
- Responsive layout, labels, keyboard/screen-reader access, high contrast/WCAG 2.1 AA, themes, and registration CTA.
- Secure transport/session handling, rate limiting, analytics privacy, support path, dashboard handoff, page performance, and capacity goals.

Out of scope

- Post-login VWO workflows beyond verifying successful handoff and account context.
- Future enhancements listed by the PRD: biometric authentication, adaptive authentication, PWA, personalized login, and expanded behavior analytics/A-B testing unless separately approved.
- Certifying GDPR/CCPA or OWASP compliance from functional tests alone; specialist evidence and accountable review are required.

4. Assumptions and Dependencies

- The PRD has no stable requirement IDs. RQ-* labels below are test-plan trace labels derived from PRD topics, not source requirement identifiers.
- MFA, SSO, social login, dark mode, and remember-me depend on release configuration; confirm scope and test enabled features.
- An isolated test environment, synthetic accounts, test identity providers, non-production reset-email sink, and analytics sink are available. Never use production credentials or personal data.
- Owners must specify session timeout, password policy, lockout/rate-limit thresholds, generic-error policy, supported SSO providers, and analytics schema.

- Performance measurement conditions and the observation window for 99.9% uptime are undefined; agree them before setting release gates.
- Email, identity provider, support, analytics, CDN, and core-platform dependencies need test doubles or dedicated test tenants with known failure behavior.

5. Risk Assessment

Area	Failure risk	Likelihood	Impact	Mitigation / planned coverage	Priority
Credentials	Unauthorized access, denied valid users, or account-state disclosure.	Medium	High	Positive/negative tests; generic errors; security and analytics review.	P0
Session / remember-me	Session misuse, persistence against user choice, or timeout failure.	Medium	High	Token/configuration review; persistence, expiry, and re-authentication tests.	P0
Password recovery	Unauthorized reset, reusable/expired token, or account enumeration.	Medium	High	Safe-response comparison; token lifecycle and password-policy tests.	P0
MFA / SSO	Authentication bypass, failed enterprise access, or wrong account mapping.	Medium	High	Test IdP; denial, expiry, claim, and outage paths; conditional on scope.	P0
Rate limiting	Automated guessing not throttled or legitimate users blocked.	Medium	High	Bounded staging tests against agreed policy and recovery behavior.	P0
Transport / data	Credentials or tokens exposed in transit, logs, or browser storage.	Low-Med	High	TLS, storage, and log review with security evidence.	P0
Accessibility / mobile	Login cannot be completed with assistive technology or on mobile.	Medium	Med-High	Keyboard/screen-reader checks; contrast and responsive viewports.	P1
Integrations	Successful auth fails dashboard handoff or provider outage blocks recovery.	Medium	High	Handoff/account-context and dependency-failure scenarios.	P1
Performance / capacity	Slow page or degraded auth during traffic spikes.	Medium	High	Measure <2s target; load test thousands with agreed profile.	P1
Analytics / support	Misleading KPI, sensitive data in events, or support unavailable.	Low-Med	Medium	Payload/schema checks and support-route smoke test.	P2

6. Test Strategy

Levels: unit/component tests for validation and UI states; API/contract tests for authentication, reset, sessions, MFA/SSO, and throttling; integration tests for email, IdP, dashboard, analytics; end-to-end UI checks for critical journeys; non-functional security, accessibility, performance, compatibility, and reliability checks.

Sequence: smoke (page, form, valid login handoff); P0 critical path (auth, reset, session, rate limits, enabled MFA/SSO); P1 release regression (responsive/accessibility, integration failures, performance/load); P2 exploratory and compatibility. Run P0 smoke on each deploy and full regression for release candidates or auth/session changes.

Automate deterministic API/component cases and stable Playwright UI journeys using existing team conventions and fixtures. Use test IdP fixtures where possible. Manual checks: screen-reader usability, visual theme/contrast, exploratory recovery, provider/configuration review, and security evidence. Assert observable states, avoid arbitrary waits, and clean synthetic data.

Exploratory charters: interrupted login/reset; repeated submissions and slow responses; expired sessions; email/IdP outages; keyboard-only completion; viewport changes; and clear errors without account enumeration.

7. Environment and Test Data

Use isolated staging/pre-production with HTTPS, production-like authentication settings, test analytics sink, core dashboard, email sink, test identity providers, monitoring, and controllable throttling. Confirm supported browser/device versions with Product; cover agreed desktop and mobile browsers.

Create synthetic valid, unknown/invalid, reset-eligible, MFA-enrolled, SSO-valid/denied, expired-session, and policy-throttled accounts. Use generated non-personal addresses and run IDs; mask logs and tear down/reset accounts after runs. No production data or real credentials.

8. Test Scenarios

Expected results are observable acceptance outcomes. Priority is execution order/business risk, not defect severity. Optional capabilities are conditional on release configuration.

ID	Requirement	Scenario	Type	Priority	Expected result	Auto
TC-01	RQ-AUTH	Submit valid email/password.	E2E/API	P0	Auth succeeds; one valid session is established; correct dashboard/account opens.	Yes
TC-02	RQ-AUTH	Known account with incorrect password.	API/UI	P0	Access denied; generic actionable error; no session or account-existence disclosure.	Yes
TC-03	RQ-AUTH	Unknown email; blank or malformed credentials.	UI/API	P0	Validation follows policy; auth denied; account existence is not revealed.	Yes
TC-04	RQ-VALIDATION	Blur validation, labels, mobile keyboard hint, strength feedback, input boundaries.	UI	P1	Errors appear at defined point; labels associate; boundaries match approved rules.	Yes
TC-05	RQ-AUTH	Double submit, delay, timeout, or server error during login.	UI/API	P0	Progress shown; no duplicate session; failure is clear and recoverable.	Yes
TC-06	RQ-SESSION	Toggle remember-me; close and reopen browser.	E2E	P0	Persistence matches choice and policy; no clear-text credential storage.	Partial
TC-07	RQ-SESSION	Use expired/revoked session against protected dashboard.	API/E2E	P0	Access denied; user must authenticate again.	Yes
TC-08	RQ-PASSWORD	Request reset for existing and non-existing addresses.	API/UI	P0	Safe consistent confirmation; only eligible account receives reset message.	Yes
TC-09	RQ-PASSWORD	Valid, expired, malformed, and previously used reset tokens.	API/UI	P0	Only valid unused token within configured lifetime resets intended account.	Yes
TC-10	RQ-PASSWORD	Password policy boundaries; sign in with new and previous password.	API/E2E	P0	Compliant new password works; non-compliant rejected; old password no longer works.	Yes
TC-11	RQ-MFA	Valid, invalid, expired MFA challenge and recovery path.	API/E2E	P0	Only valid challenge completes auth; no bypass; recovery follows policy.	Conditional
TC-12	RQ-SSO	SAML/OAuth success, denial, cancellation, invalid/expired response, outage.	Integration	P0	Only validated authorized identity creates correct session; failures grant no access.	Conditional
TC-13	RQ-SOCIAL	If shipped: provider success, cancel, deny, and outage.	Integration	P1	Identity maps per approved account-linking rules; failures create no session.	Conditional
TC-14	RQ-RESPONSIVE	Login, reset, and CTA at supported mobile/tablet/desktop sizes.	UI	P1	No clipping/overlap; touch and zoom usable; primary flow needs no horizontal scroll.	Yes
TC-15	RQ-ACCESS	Complete login/reset keyboard-only and with screen reader.	Access	P1	Logical focus, visible focus, announced errors/status, and named controls.	Partial

ID	Requirement	Scenario	Type	Priority	Expected result	Auto
TC-16	RQ-ACCESS	Check contrast in Light/Dark and high-contrast modes.	Access/UI	P1	WCAG 2.1 AA contrast/focus criteria met; themes remain readable and functional.	Partial
TC-17	RQ-SIGNUP	Follow free-trial registration CTA.	E2E	P2	CTA visible/reachable and navigates to approved registration destination.	Yes
TC-18	RQ-CORE	Verify dashboard destination and account/tenant after login.	E2E	P0	Authorized user reaches intended dashboard; no other account context appears.	Yes
TC-19	RQ-ANALYTICS	Inspect auth/reset event schema and payloads.	Integration	P1	Events match schema; no password, reset token, or credential in logs/events.	Partial
TC-20	RQ-SUPPORT	Follow login-help path, including provider outage.	UI/Int	P2	Support route is reachable and provides approved help without data exposure.	Partial
TC-21	RQ-SECURITY	Review HTTPS/TLS, token handling, browser storage, password persistence, logs.	Security	P0	HTTPS enforced; no plaintext secret/token exposure; session config is approved.	Manual
TC-22	RQ-RATE	Bounded repeated failed attempts in approved staging.	Security/API	P0	Throttle enforced at agreed threshold; recovery follows policy; other users usable.	Partial
TC-23	RQ-PERF	Measure page load under agreed connection and cache conditions.	Perf	P1	Measured load meets PRD target <2 seconds under approved definition.	Partial
TC-24	RQ-SCALE	Thousands of concurrent attempts plus dependency degradation.	Load	P1	Agreed profile sustained without unauthorized access/data corruption; SLOs met.	Partial
TC-25	RQ-AVAIL	Observe availability evidence and alerting over agreed period.	Reliability	P1	Measurement window, recovery, and alert behavior meet approved SLO/runbook.	Manual
TC-26	RQ-KPI	Calculate login success from agreed eligible attempts and compare report.	Analytics	P2	Denominator agreed; measured target 95%+; failures categorized without secrets.	Partial

9. Requirements Traceability Matrix

PRD area / plan trace label	Scenarios	Coverage / gap
Authentication (RQ-AUTH)	TC-01 to TC-05	Covered; confirm rate/error policy.
Field validation (RQ-VALIDATION)	TC-03, TC-04	Exact validation and strength rules need specification.
Password recovery (RQ-PASSWORD)	TC-08 to TC-10	Token lifetime and password policy need specification.
Session / remember-me (RQ-SESSION)	TC-06, TC-07, TC-18, TC-21	Timeout and persistence policy TBD.
Optional MFA (RQ-MFA)	TC-11	Conditional; release scope and recovery method TBD.
Enterprise SSO (RQ-SSO)	TC-12	Conditional; providers, claims, account mapping TBD.
Optional social login (RQ-SOCIAL)	TC-13	Conditional; provider list and account-linking behavior TBD.
Responsive / themes (RQ-RESPONSIVE)	TC-14, TC-16	Supported viewport/browser matrix TBD.
Accessibility (RQ-ACCESS)	TC-04, TC-15, TC-16	Manual assistive-tech review required for WCAG 2.1 AA.

PRD area / plan trace label	Scenarios	Coverage / gap
Registration CTA (RQ-SIGNUP)	TC-17	Destination/tracking expectation TBD.
Core dashboard (RQ-CORE)	TC-01, TC-18	Destination/account-context contract TBD.
Analytics (RQ-ANALYTICS)	TC-19, TC-26	Event schema and KPI definition TBD.
Customer support (RQ-SUPPORT)	TC-20	Support channel and outage behavior TBD.
Transport / data security	TC-02, TC-06, TC-09, TC-21	Specialist security evidence and configuration review required.
Rate limiting (RQ-RATE)	TC-22	Threshold, duration, recovery policy TBD.
Page load (RQ-PERF)	TC-23	PRD target <2s; measurement method TBD.
Availability / scale	TC-24, TC-25	PRD says 99.9% and thousands; workload/window TBD.
Success KPI (RQ-KPI)	TC-01 to TC-03, TC-26	PRD target 95%+; denominator/reporting window TBD.
GDPR/CCPA, OWASP, audit	TC-19, TC-21 plus specialist evidence	Functional tests do not certify compliance; map owners/evidence.

10. Execution Plan

Phase	Activities	Owner	Dependencies / completion
0. Readiness	Confirm scope, rules, environment, accounts, provider setup, test data.	QA / Product / Security (TBD)	Stable build; owners agree P0 behavior and fixtures.
1. Core smoke	Page/form, valid/invalid auth, loading/errors, dashboard handoff, reset request.	QA (TBD)	Run on each deploy; resolve environment blockers.
2. P0 critical path	Auth, reset/token/policy, session, throttling, enabled MFA/SSO, security review.	QA + Auth/Security (TBD)	P0 pass; security evidence available.
3. P1 regression	Responsive/accessibility, integration failures, <2s load, concurrency/availability evidence.	QA + Accessibility/Perf/Ops (TBD)	Profiles agreed; risks documented.
4. P2/sign-off	Registration/support UX, KPI, exploration, compatibility, defect/risk review.	QA + Product (TBD)	Residual risk accepted; release approval recorded.

11. Entry and Exit Criteria

Entry

- Stable release candidate in isolated environment; build/version and feature flags recorded.
- P0-gating rules (password/session/throttle behavior, enabled auth methods, failure copy) have owners and testable agreement.
- Synthetic accounts, providers, reset/analytics sinks, monitoring, and access verified; no production data.
- Scenarios, browser/device matrix, performance profile, and defect process approved.

Exit / release gate

- All P0 scenarios pass; no open Critical/Blocker and no unaccepted High auth/security defect.
- All in-scope P1 tests complete; failures have documented disposition and owner approval.
- Page-load measurement meets <2s under agreed method. Report performance/availability against signed-off profiles; a short run does not prove annual 99.9% uptime.
- No unresolved WCAG 2.1 AA blocker in critical flows, or documented approved exception.

- Security review covers transport, credential/token handling, throttling, and enabled identity flows; critical/high issues fixed or explicitly accepted.
- Results, environment, run IDs, defects, untested areas, residual risks, and Product/Engineering/Security/QA sign-off published.

12. Defect Management and Reporting

Log build/environment, feature flags, scenario ID, reproducible steps, expected/actual behavior, sanitized evidence, and user impact. Never attach real credentials, reset tokens, or personal data. Triage daily during release execution; immediately escalate Critical/High auth or security issues to Engineering and Security.

Severity	Working definition	Release handling
Critical / Blocker	Unauthorized access, systemic login outage, secret exposure, or unrecoverable critical journey.	Stop release; fix/retest or obtain exceptional accountable risk decision.
High	Major user/enterprise login failure, severe security issue, or critical accessibility barrier.	Block by default; fix/retest or document accountable acceptance.
Medium	Degraded secondary flow or limited compatibility with workaround.	Triage; document workaround, owner, and deferral if applicable.
Low	Cosmetic or low-impact issue; task still completes.	Backlog priority; disclose if visible in release.

Report per run: pass/fail/blocked by priority; coverage; defects by severity/age; outcome counts and KPI denominator; load profile, errors/latency, page-load measurements, accessibility findings, environment, and residual risks. This plan does not claim tests have run.

13. Risks, Open Questions, and Decisions Needed

- Which features ship now: MFA, SSO, social login, dark mode, remember-me? Which providers/protocols are required?
- What are password rules/history, reset-token lifetime/reuse, session timeout, remember-me duration, logout/revocation, and lockout recovery?
- What invalid-login/reset copy and account-enumeration protections are required?
- What rate-limit threshold/window, response, block duration, recovery, and safe staging test limit apply?
- Define <2s metric, percentile, geography, connection, cache, browser, and sample count; define concurrency and acceptable latency/error thresholds.
- What measurement window and monitoring define the 99.9% availability goal; is it an operational SLO rather than release test?
- Confirm browser/OS/device matrix, registration destination, dashboard contract, analytics schema/KPI denominator, and support channels.
- Who owns GDPR/CCPA, OWASP, audit-trail, and retention evidence and signs off?
- Are expanded analytics/A-B testing in this release, or deferred as future enhancements in the PRD?